

Penetration Test Report

Prepared by Sablecrest Security for Kestrellyn - Report date: 2026-05-20

Scope: this report covers the customer product, Kestrellyn Ledger.

Summary

Sablecrest Security, an independent third party, performed this penetration test of Kestrellyn Ledger in May 2026.

Testing ran from 2026-05-04 to 2026-05-15 against a staging environment that mirrors production, using test customer tenants created for this engagement. Sablecrest Security found no critical-severity and no high-severity issues. Five findings are reported in total: two medium, two low and one informational.

Two medium-severity findings remain open as of the report date.

Scope and Methodology

The test covered the Kestrellyn Ledger web application and its public API. The corporate network and third-party services were out of scope.

Testers worked in a grey-box setting with two standard users and one tenant administrator in each of two test tenants. Testing was manual and followed the OWASP Web Security Testing Guide. It covered authentication and session handling, authorization between tenants, input handling, business logic and file handling.

Testing was limited to ten working days, so this report reflects the state of the staging environment during that window only.

Severity Ratings

Each finding is rated by combining how likely it is to be exploited with the impact if it is. The scale has four levels: critical, high, medium and low. Informational items have no direct security impact and are listed for completeness.

Authentication Observations

During authentication testing, Sablecrest Security observed the following.

MFA is not yet enforced for customer administrator accounts in Kestrellyn Ledger.

Findings

ID: KL-26-01; Title: No rate limiting on the invoice export endpoint; Severity: Medium; Status: Open

ID: KL-26-02; Title: Session tokens remain valid after logout; Severity: Medium; Status: Open

ID: KL-26-03; Title: Pagination limit can be raised above the documented maximum; Severity: Low; Status: Remediated

ID: KL-26-04; Title: Predictable file names for exported reports; Severity: Low; Status: Remediated

ID: KL-26-05; Title: Deprecated v1 API route still answers requests; Severity: Informational; Status: Accepted

KL-26-01 No rate limiting on the invoice export endpoint

A single user can call the invoice export endpoint repeatedly without being slowed down, which lets one tenant place a large load on shared resources. Sablecrest Security recommends per-tenant limits on export requests.

KL-26-02 Session tokens remain valid after logout

A session token issued before a user logs out can still be used until it expires. Sablecrest Security recommends invalidating the token on the server when the user logs out.

Remediation Status

Kestrellyn fixed both low-severity findings during the engagement, and Sablecrest Security confirmed both fixes on 2026-05-19. The two medium-severity findings are scheduled for upcoming engineering work. The informational item was accepted by Kestrellyn.